

Clase 3

Framework de Seguridad para IoT

- **NIST IR 8259 (EE. UU., 2020):** Define un *IoT Device Cybersecurity Capability Core Baseline*, estableciendo requisitos esenciales de autenticación, actualizaciones, cifrado y logging.
 - **ISO/IEC 27400 (2022):** Proporciona directrices de gestión de riesgos de ciberseguridad en IoT, cubriendo dispositivos, gateways y plataformas en la nube.
 - **ISO/IEC 30141 (2018):** Arquitectura de referencia IoT, sirve como guía para estandarizar la estructura de dispositivos y plataformas interoperables.
 - **ETSI EN 303 645:** Establece requisitos básicos de ciberseguridad para dispositivos IoT de consumo, incluyendo prácticas de privacidad y protección de datos.
 - **OWASP IoT Project Top 10 (2021):** Lista los principales riesgos de seguridad en IoT, ayudando a priorizar medidas de mitigación.
 - **ENISA Guidelines:** Guías específicas para smart homes, eHealth, smart cars y smart infraestructures, incluyendo riesgos y buenas prácticas.
-

Frameworks de Interoperabilidad IoT

- **AIOTI (Alliance for Internet of Things Innovation):** Promueve estándares abiertos y recomendaciones para la interoperabilidad de IoT en la UE.
 - **oneM2M:** Estándar global con fuerte adopción europea que define funciones comunes de servicios IoT, incluyendo *Security Functions* como autorización y cifrado extremo a extremo.
 - **FIWARE (iniciativa UE):** Framework open source para interoperabilidad IoT y smart cities, integrando NGSI API, módulos de Identity Management y ciberseguridad para garantizar confianza entre plataformas.
 - **ETSI SmartM2M:** Complemento europeo de oneM2M que promueve semántica común, APIs abiertas y directrices de seguridad aplicadas en interoperabilidad.
-

Relación Seguridad IoT e Interoperabilidad IoT

- La interoperabilidad requiere seguridad: identidad, autenticación y cifrado son esenciales para intercambiar datos confiables entre plataformas.
 - **ETSI EN 303 645** se complementa con **ETSI SmartM2M** y **oneM2M**, integrando la seguridad como requisito transversal.
 - **FIWARE y AIOTI** aplican principios de *privacy by design* y *security by design*, asegurando interoperabilidad segura.
 - Frameworks de seguridad como **NISTIR 8259** e **ISO/IEC 27400** sirven de base para garantizar plataformas interoperables a nivel internacional.
-

Principales amenazas

ENISA 2024

- DOS / DDOS / RDOS (Ransom Denial of Service)
- Ransomware
- Robo de datos personales/sensibles
- Social Engineering
- Malware
- Ataques a cadena de suministro
- Amenazas web
- File Integrity Monitoring and Incident Detection (FIMI)
- Ataques Zero Day

CISO (Feb 2024)

- Ransomware
- Malware
- Fraude por correo electrónico (compromiso de cuentas corporativas)
- Compromiso de cuentas en la nube
- Amenaza interior (negligencia, accidente o intencional)
- Ataques DDOS

- Ataques a cadena de suministro
- Smishing / Vishing (phishing vía SMS o voz)

Data Breach Investigations Report – Verizon 2024/2025

- System Intrusion: 36 % → 52 %
- Miscellaneous Errors: 25 % → 12 %
- Social Engineering: 22 % → 17 %
- Basic Web Application Attacks: 9 % → 12 %
- Privilege Misuse: 8 % → 6 %

(Universo de 22.052 incidentes con 12.195 brechas de datos confirmadas)

WEF Global Cybersecurity Outlook 2025

- Ransomware sigue siendo riesgo N°1, potenciado por phishing, BEC y vishing.
- Generative AI (GenAI) amplifica campañas de phishing y deepfakes multilingües y a escala.
- Convergencia con crimen organizado → mayor impacto social y blancos críticos.
- Paradoja IA: solo 37 % de organizaciones evalúa seguridad de herramientas de IA.
- Uso de IA para defensa: detección temprana, triage, priorización, análisis de anomalías.
- Honeypots con LLMs: interacción dinámica para aprendizaje de ataques.
- Amenaza cuántica: evaluación de riesgos emergente.
- Interdependencias: cadena de suministro crítica, concentración de proveedores, tensiones geopolíticas y regulaciones complejas afectan resiliencia y estrategia.
- Resiliencia: cultura de apertura, reporte temprano, cooperación público-privada y gestión de vulnerabilidades esenciales.

Bases de datos de vulnerabilidades

- **CVE (Common Vulnerabilities and Exposures):** Sistema estandarizado de identificación de vulnerabilidades gestionado por MITRE. Cada vulnerabilidad recibe un identificador único (ej.: CVE-2017-0144 – WannaCry).
 - **NVD (National Vulnerability Database):** Base de datos del NIST que amplía la información de CVE con CVSS, CPE, CCE, parches y referencias técnicas. Ejemplo: Log4Shell → CVE-2021-44228 → CVSS 10.0 (Crítico) con versiones afectadas y guías de mitigación.
 - **Relación CVE/NVD:** CVE = “etiqueta universal”; NVD = expansión técnica y gestión de riesgos.
-

Ejemplos de ciberataques

- **Costa Rica 2022:**
 - Ministerio de Hacienda y Ministerio de Ciencia, Innovación, Tecnología y Telecomunicaciones atacados por Conti.
 - Caja Costarricense de Seguro Social atacada por Hive, obligando cierre de sistemas críticos de salud digital.
 - Solicitudes de rescate de 5–20 millones USD.
 - **Incremento global:**
 - +38 % ciberataques 2022 vs 2021; +30 % 2T 2024.
 - Sectores más atacados: Educación/Investigación, Gobierno/Militar, Salud.
 - América Latina +53 %, África +37 %, Europa +35 %.
 - **Ransomware en IES:** Más de la mitad pagó rescate; quienes usaron backups tuvieron costos significativamente menores.
-

Impactos de un ciberataque

- **Económico/Financiero:** directos e indirectos.
 - **Imagen y prestigio:** afectación de servicios y reputación en redes sociales.
 - **Otros:** salud y continuidad operativa.
-

Frameworks y Regulaciones en Ciberseguridad

NIST Cybersecurity Framework (CSF 2.0)

- Funciones: Identificar, Proteger, Detectar, Responder, Recuperar, Gobernar.
- Permite gestionar riesgos, supervisar controles y asegurar continuidad operativa.

ISO/IEC 27000 Family

- **ISO/IEC 27001:** Requisitos para establecer, implementar y mejorar un SGSI.
- **ISO/IEC 27002:** Buenas prácticas y controles de seguridad.
- **ISO/IEC 27005:** Gestión de riesgos.
- Controles adicionales: 27017 (cloud), 27018 (protección de datos en nube), 27032 (ciberseguridad), 27035 (gestión de incidentes), entre otros.

CIS Critical Security Controls v8

- 18 controles priorizados por importancia (IG1-IG3 según tamaño de la organización).
- Áreas: inventario de activos, protección de datos, gestión de vulnerabilidades, auditoría y logging, defensa de red, concienciación, gestión de proveedores, respuesta a incidentes, pentesting.

Otros frameworks/regulaciones

- **COBIT:** Gobernanza y gestión TI.
- **GDPR / CCPA:** Protección de datos y privacidad.
- **CMMC:** Madurez de ciberseguridad para contratistas del DoD.
- **HIPAA:** Seguridad de información sanitaria.
- **PCI DSS:** Seguridad en pagos con tarjeta.
- **Reglamento Europeo de Ciberseguridad:** Certificación de productos digitales y servicios de seguridad gestionados.

Políticas y estructura organizacional

- Comité de Ciberseguridad y CISO: definir estrategia, gestionar políticas y riesgos, coordinar SOC/CSIRT/IT/Legal.
 - Director de Privacidad / CPO: cumplimiento de GDPR/CCPA, manejo de datos personales, derecho al olvido.
 - Política de cookies: almacenamiento, personalización, análisis de rendimiento, selección de anuncios.
-

SOC / CSIRT

SOC (Security Operations Center)

- Monitoreo en tiempo real: Zabbix, Nagios, Prometheus + Grafana, ElastAlert.
- SIEM/EDR: Wazuh, TheHive, Suricata, Snort, Osquery.
- Procesamiento y análisis: ELK Stack (Elasticsearch, Logstash, Kibana).
- Flujo integral: detección (Wazuh/Suricata) → análisis (ELK) → respuesta (TheHive/Cortex) → inteligencia (MISP) → remediación (Velociraptor).

CSIRT (Computer Security Incident Response Team)

- Gestión de incidentes: TheHive, RTIR.
- Coordinación externa: MISP, OpenDXL.
- Análisis forense: Autopsy, Sleuth Kit, Volatility, Plaso.
- Planes de recuperación: DRLM, Odoo, LibreNMS + Ansible.

Herramientas destacadas

- Wazuh: SIEM + EDR.
- ELK Stack: análisis y visualización de logs.
- Suricata / Snort: IDS/IPS.
- TheHive + Cortex + MISP: gestión y automatización de incidentes